AUDIT REPORT · AUD-2026-IAM-01

# Strong authentication and privileged access — KRL-ADM

Banque Ardoise (fictive) · Annuaire des accès

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:21**

Run: **07-ardoise-grand-annuaire**

## 1. Executive summary

OPINION AT TESTING

**Needs improvement**

| | | | |
|---|---|---|---|
| **7** controls tested | **1** findings | **0** findings closed and verified | **1** open findings |
| **0** human approvals | **112** personal data items masked in evidence | **0 min 36 s** audit duration | **$0.591 *** measured AI cost |

Critical: 0 High: 1 Medium: 0 Low: 0

### Key messages

- 1 finding across 7 controls: 1 high.
- 1 finding remains open, with an action plan, an owner and a due date.

## 2. Scope and method

| | |
|---|---|
| Engagement | AUD-2026-IAM-01 |
| Entity | Banque Ardoise (fictive) |
| System | Annuaire des accès |
| System criticality | Supporte des fonctions critiques ou importantes (DORA) |
| Environment | Pré-production de démonstration |
| Owner | DSI — équipe IAM |
| Lead auditor | A. Auditeur |
| Date | 2026-11-02 23:21 |
| Framework | DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4 |
| Work programme | existing catalogue reused · controls/AUD-2026-IAM-01.en.json |

### In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

### Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

### Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

### Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

## 3. Findings overview

| REF. | RULE | TITLE | SEVERITY | TESTED | AFTER | STATUS | DUE DATE |
|---|---|---|---|---|---|---|---|
| F-01 | PSI-4.7 | No generic or shared admin accounts | High | Non-compliant | | Open | 2027-01-31 |
| — | PSI-4.1 | Mandatory MFA for privileged accounts | Critical | Compliant | | | |
| — | PSI-4.2 | Mandatory MFA for users of critical system | High | Compliant | | | |
| — | PSI-4.3 | Strong password policy | Medium | Compliant | | | |
| — | PSI-4.4 | Account lockout after failed logins | Medium | Compliant | | | |
| — | PSI-4.5 | Inactive session timeout | Medium | Compliant | | | |
| — | PSI-4.6 | Logging of administration actions | High | Compliant | | | |

## 4. Detailed findings and controls

**F-01 PSI-4.7** No generic or shared admin accounts — High — Non-compliant — Open

### CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)

### CONDITION

Observed: `[{"login": "r.quere", "email": "r•••@banque-ardoise.example", "role": "admin"}, {"login": "a.richard", "email": "a•••@banque-ardoise.example", "role": "admin"},…`

Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 4 admin account(s) violate nominative login or personal email requirements.

### RISK

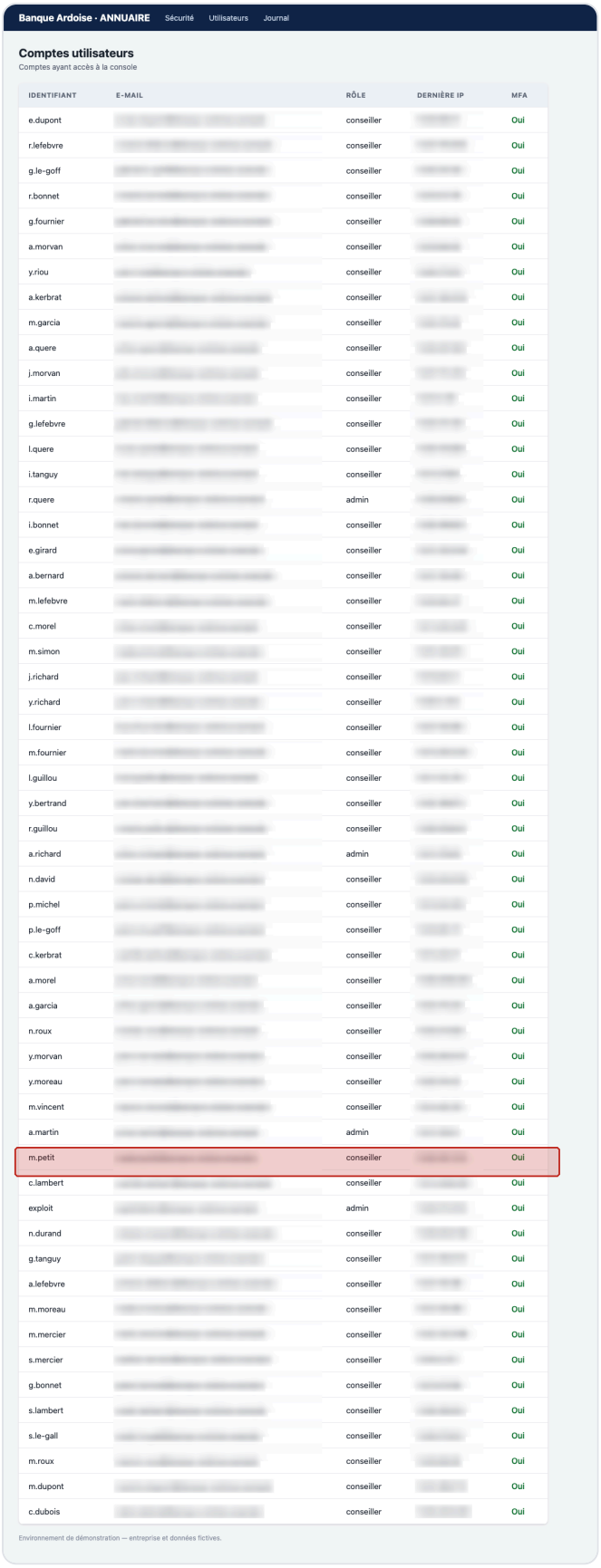
Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

### RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts

Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox




**At testing** — The screenshot corroborates the test. The screenshot shows the generic admin account exploit using a shared function mailbox. · 112/112 personal data items masked (56 spotted by the AI, the rest by the deterministic safety net)

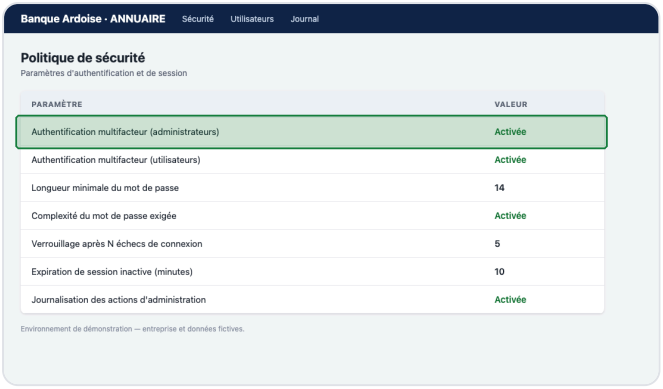
`2026-11-02 23:21:54 · SHA-256 95acdfc278589fb8…`

## PSI-4.1 Mandatory MFA for privileged accounts

Critical Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)

Observed: `true`




**At testing** — The screenshot corroborates the test. The screenshot shows administrator MFA as Activée, matching the API result of mfa_admin true.

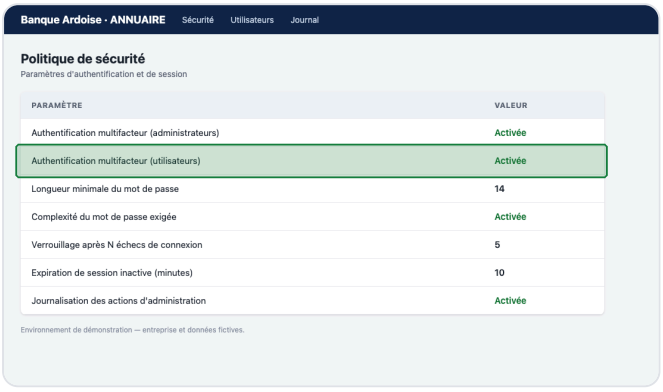
2026-11-02 23:21:24 · SHA-256 523e6d609300a659…

## PSI-4.2 Mandatory MFA for users of critical system

High Compliant

Compliant control — MFA is enforced for standard users because KRL-ADM supports critical or important functions · DORA 9(4)(d), RTS 21(1)(f)(ii)

Observed: `true`




**At testing** — The screenshot corroborates the test. The security policy table shows MFA for standard users as Activée, matching the automated pass result.

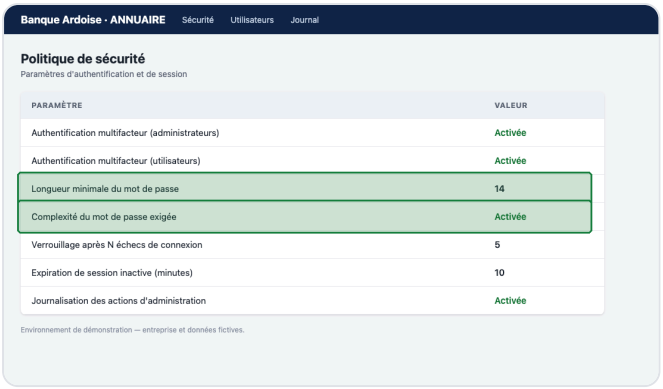
2026-11-02 23:21:26 · SHA-256 d2705d0fcd7830df…

## PSI-4.3 Strong password policy

Medium Compliant

Compliant control — Passwords require a minimum length of 12 characters with complexity requirements enabled · DORA 9(4)(d)

Observed: `{"password_min_length": 14, "password_require_complexity": true}`

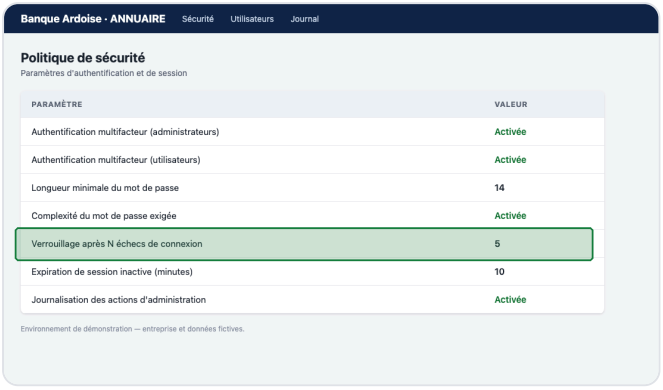



**At testing** — The screenshot corroborates the test. The screenshot shows minimum length 14 and complexity enabled, matching the automated pass result.
`2026-11-02 23:21:25 · SHA-256 2fcf2bc878c041e6…`

## PSI-4.4 Account lockout after failed logins

Medium · Compliant

Compliant control — Accounts lock after at most 5 failed login attempts and lockout is never disabled · DORA 9(4)(c)
Observed: `5`

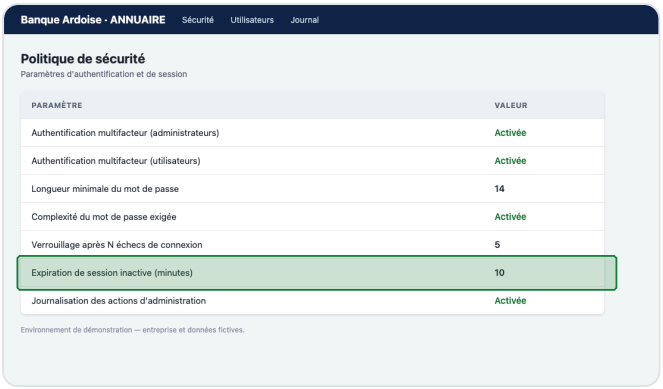



**At testing** — The screenshot corroborates the test. The security policy table shows lockout after 5 failed logins, matching the automated result of 5.
`2026-11-02 23:21:26 · SHA-256 e69d91ba84bcf906…`

## PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Inactive sessions expire after at most 15 minutes and expiration is never disabled · DORA 9(4)(c)
Observed: `10`




**At testing** — The screenshot corroborates the test. The screenshot shows inactive session expiration set to 10 minutes, which is within the required 1 to 15 range.

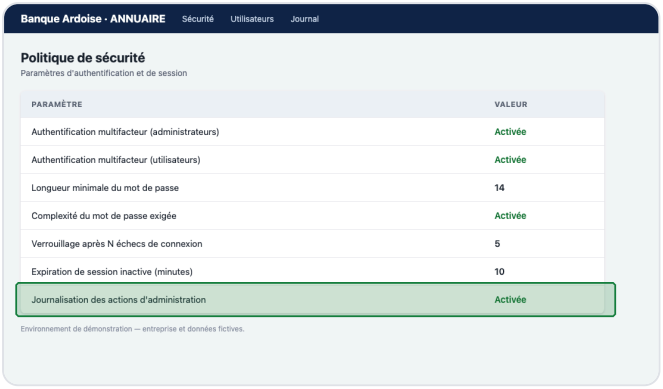
`2026-11-02 23:21:25 · SHA-256 4ed0495a575d3351…`

## PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)

Observed: `true`




**At testing** — The screenshot corroborates the test. The security policy table shows admin action logging as Activée.

`2026-11-02 23:21:24 · SHA-256 98e94702ee463d1d…`

# Appendices

## A. Traceability matrix

| REQUIREMENT | RULE | CONTROL | SCRIPT (SHA-256) | RESULT |
|---|---|---|---|---|
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.1 | C1 · Mandatory MFA for privileged accounts | 098d37cd0158dd1a · script library (reused) | Compliant |
| DORA 9(4)(d), RTS 21(1)(f)(ii) | PSI-4.2 | C2 · Mandatory MFA for users of critical system | fa35c17fbb1dfdd3 · script library (reused) | Compliant |
| DORA 9(4)(d) | PSI-4.3 | C3 · Strong password policy | b440a5b4dc6b0fb3 · script library (reused) | Compliant |
| DORA 9(4)(c) | PSI-4.4 | C4 · Account lockout after failed logins | 10d2a8f06337b5bc · script library (reused) | Compliant |
| DORA 9(4)(c) | PSI-4.5 | C5 · Inactive session timeout | 4157e9750f010f98 · script library (reused) | Compliant |
| RTS 12(2)(c)(i) | PSI-4.6 | C6 · Logging of administration actions | e2f3534909210977 · script library (reused) | Compliant |
| DORA 9(4)(c), RTS 21(1)(c), RTS 21(3) | PSI-4.7 | C7 · No generic or shared admin accounts | 5e917770866b8e47 · script library (reused) | Non-compliant |

## B. Evidence register

| FILE | | | SHA-256 |
|---|---|---|---|
| evidence/C1_before.png | C1 · At testing | 2026-11-02 23:21:24 | 523e6d609300a659731e44d89461f7b871728893f1478a4222b929a1f002d913 |
| evidence/C2_before.png | C2 · At testing | 2026-11-02 23:21:26 | d2705d0fcd7830df17ad6056d649644e6bdcbbc52e9bb2538acfd4e19e121378 |
| evidence/C3_before.png | C3 · At testing | 2026-11-02 23:21:25 | 2fcf2bc878c041e678fd75ab4550efaec4094ffc0a3c752927c1adbf2a8b8fd3 |
| evidence/C4_before.png | C4 · At testing | 2026-11-02 23:21:26 | e69d91ba84bcf90649c1c100dee31a97b0bc7be360adafb8f538ba47e3df1b8f |
| evidence/C5_before.png | C5 · At testing | 2026-11-02 23:21:25 | 4ed0495a575d335145043e80f1301a4cf26b2759886374fd05335dfbbe2ae225 |
| evidence/C6_before.png | C6 · At testing | 2026-11-02 23:21:24 | 98e94702ee463d1d8923b4baef8123310399df9e5ab260b1d901856e5e417c0c |
| evidence/C7_before.png | C7 · At testing | 2026-11-02 23:21:54 | 95acdfc278589fb8998fc4070f8345f3de2a181f08ab9616025acb0524527311 |

## C. AI usage, costs and human oversight

| MODEL | CALLS | INPUT TOKENS | OUTPUT TOKENS | IMAGES | COST (USD) |
|---|---|---|---|---|---|

| | | | | | |
|---|---|---|---|---|---|
| `muse-spark-1.3` | 57 | 82,882 | 114,693 | 0 | 0.5910 |
| `sam-3.1` | 43 | 0 | 0 | 43 | price not published |
| **Total** | | | | | **0.5910** |

Personal data in evidence: 56/112 spotted by Muse Spark + SAM, 112/112 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

## Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

## D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`6b53633003cff12934cccbf54d53af22dfcceaf2c93d4bac58aa2f9e0874e8e4`